

1. Introduzione

Nel corso dell'esercizio abbiamo allestito su Kali Linux una piattaforma di test chiamata DVWA (Damn Vulnerable Web Application), pensata per sperimentare tecniche di penetration testing. L'obiettivo è stato muovere i primi passi nell'analisi e nell'exploit di vulnerabilità web reali, imparando a configurare servizi e a utilizzare strumenti di proxying come Burp Suite.

2. Configurazione dell'Ambiente di Rete

Abbiamo scelto la modalità Bridged in VirtualBox per garantire a Kali Linux un IP sulla stessa rete del host. Questo approccio semplifica la comunicazione con il browser e con Burp Suite. Il test di connettività via ping ha confermato l'accesso a Internet e l'allineamento delle interfacce di rete.

3. Installazione di DVWA e Configurazione del Database

Dal terminale in root siamo entrati in `/var/www/html`, clonato il repository DVWA e regolati i permessi di scrittura. In seguito, abbiamo avviato MySQL, creato il database `dvwa` e l'utente `kali` con tutti i privilegi sullo schema dedicato. Questa separazione garantisce che eventuali reset o crash interessino solo l'applicazione vulnerabile, senza compromettere altri dati.

```
root@kali: /var/www/html/DVWA/config
File Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# cd /var/www/html
(root@kali)-[/var/www/html]
# git clone https://github.com/digininja/DVWA
Cloning into 'DVWA' ...
remote: Enumerating objects: 5373, done.
remote: Total 5373 (delta 0), reused 0 (delta 0), pack-reused 5373 (from 1)
Receiving objects: 100% (5373/5373), 2.58 MiB | 6.30 MiB/s, done.
Resolving deltas: 100% (2667/2667), done.
(root@kali)-[/var/www/html]
# chmod -R 777 DVWA/
(root@kali)-[/var/www/html]
# cd DVWA/config
(root@kali)-[/var/www/html/DVWA/config]
# cp config.inc.php.dist config.inc.php
(root@kali)-[/var/www/html/DVWA/config]
# nano config.inc.php
(root@kali)-[/var/www/html/DVWA/config]
#

root@kali: /home/kali
File Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# service mysql start
(root@kali)-[/home/kali]
# mysql -u root -p
Enter password:
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.4.5-MariaDB-1 Debian n/a

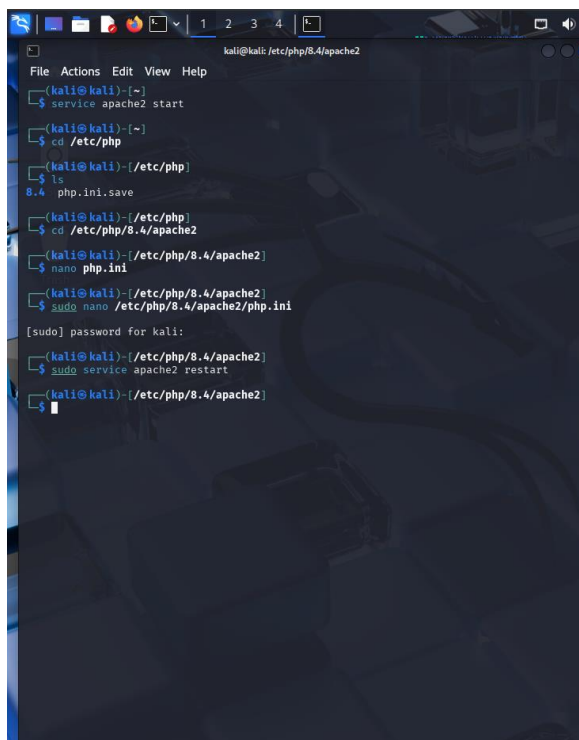
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
```

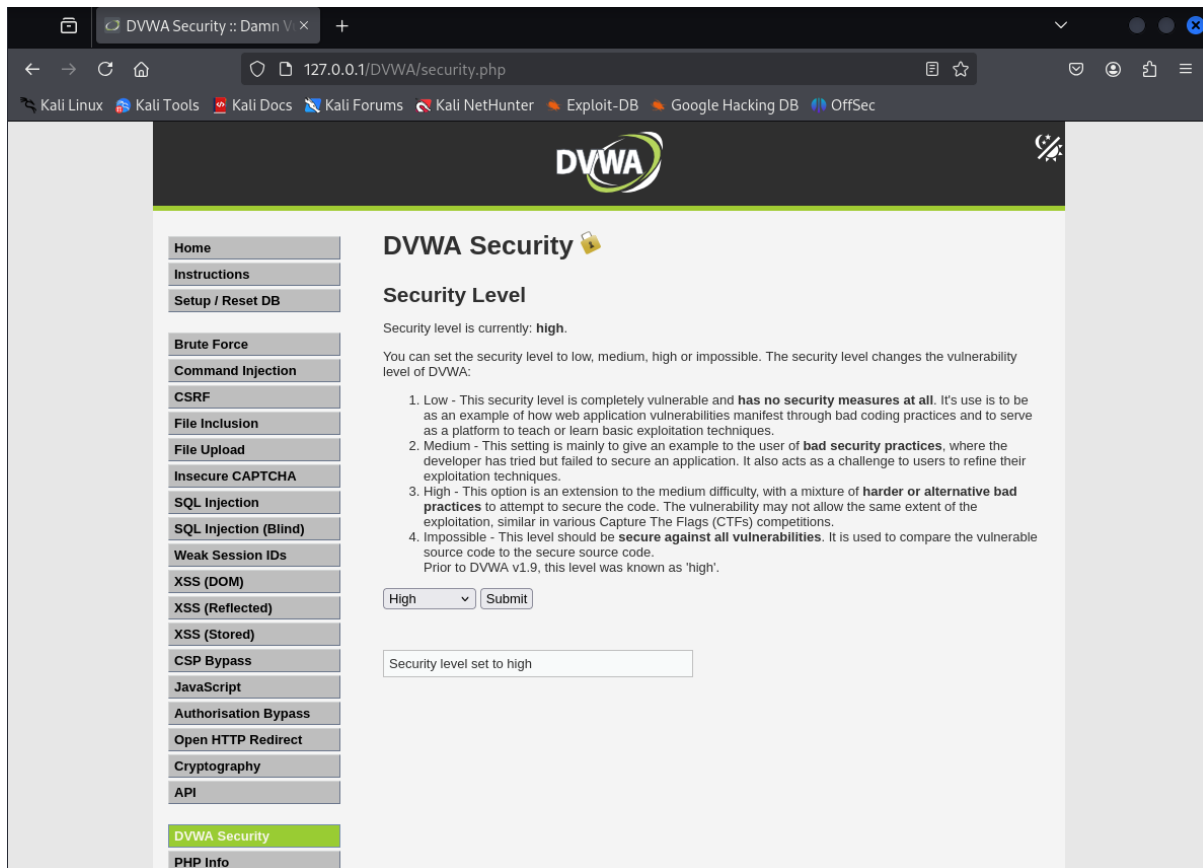
4. Configurazione di Apache e PHP

Avviato Apache2, abbiamo adattato il file `php.ini` attivando `allow_url_fopen` e `allow_url_include`, parametri essenziali per i laboratori di file inclusion. Il riavvio di Apache ha reso effettive le modifiche, assicurando che DVWA potesse eseguire include remoti e testare le vulnerabilità di inclusione di file.

A terminal window on a Kali Linux system. The prompt is 'kali@kali: /etc/php/8.4/apache2'. The user runs 'service apache2 start', then 'cd /etc/php', then 'ls', which shows '8.4' and 'php.ini.save'. They run 'cd /etc/php/8.4/apache2', then 'nano php.ini', and then 'sudo nano /etc/php/8.4/apache2/php.ini'. A password prompt '[sudo] password for kali:' is shown. Finally, they run 'sudo service apache2 restart' and the prompt returns to 'kali@kali: /etc/php/8.4/apache2'.

5. Setup Iniziale di DVWA

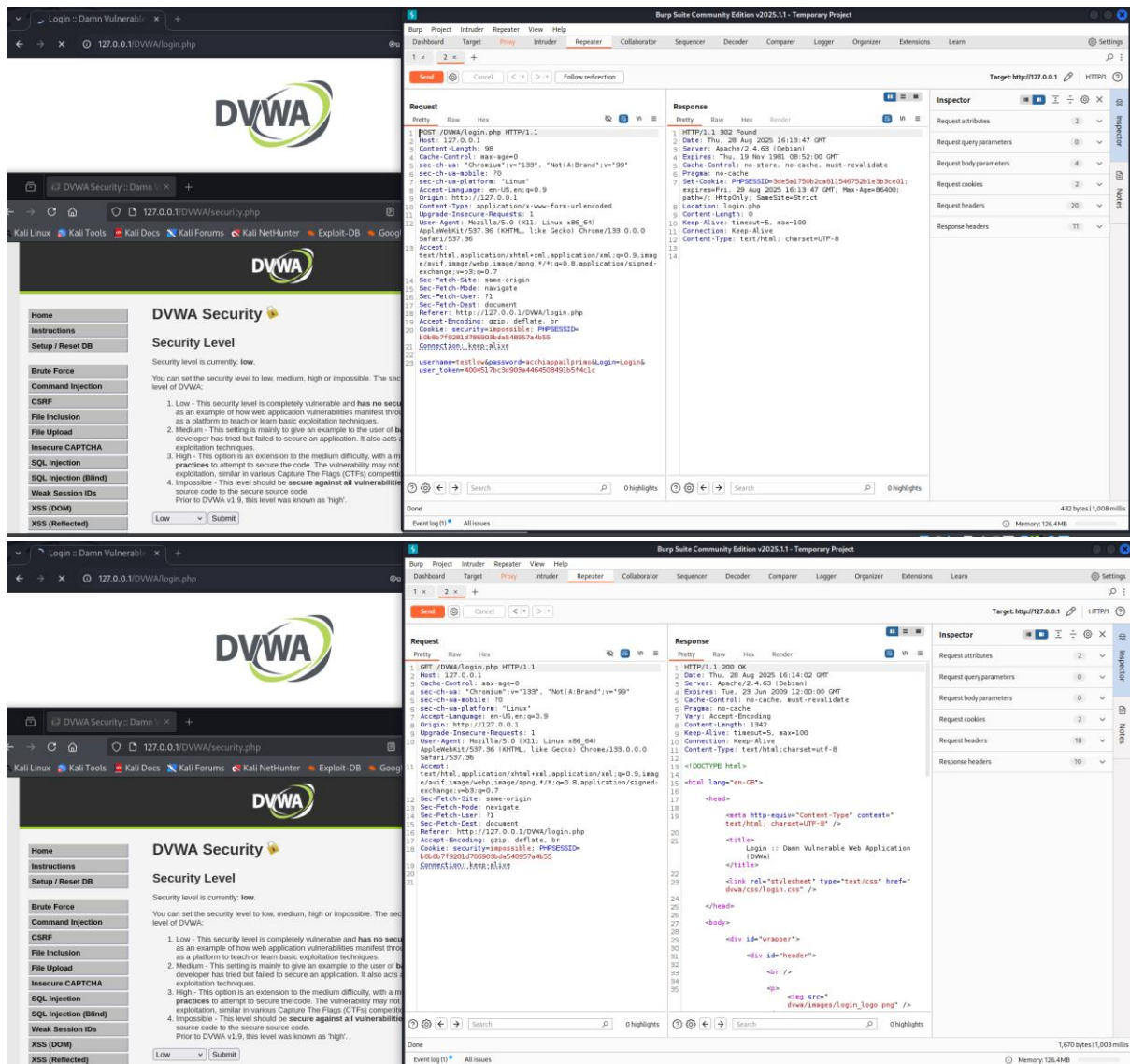
Accedendo a <http://127.0.0.1/DVWA/setup.php>, abbiamo creato e resettato il database con un click. Dopo la procedura di setup, il login con “admin/password” ha confermato il corretto collegamento tra web server, PHP e database MySQL, permettendo di entrare nell’interfaccia e selezionare il livello di sicurezza “low”.



6. Analisi del Login con Burp Suite

Con Burp Suite in ascolto (Proxy → Intercept → on) abbiamo intercettato la richiesta POST verso `/DVWA/login.php`, esaminato header e body, e inoltrato la request al Repeater. Questa fase ha sottolineato l'importanza del token CSRF e dei cookie di sessione, evidenziando come modifiche arbitrarie ai parametri di login portino immediatamente a un "Login failed".

Login.php significa login fallito. Il server ha ricevuto le credenziali (username e password), ma non le ha riconosciute come valide. DVWA ci riporta alla pagina di login per riprovare.



7. Parte Facoltativa

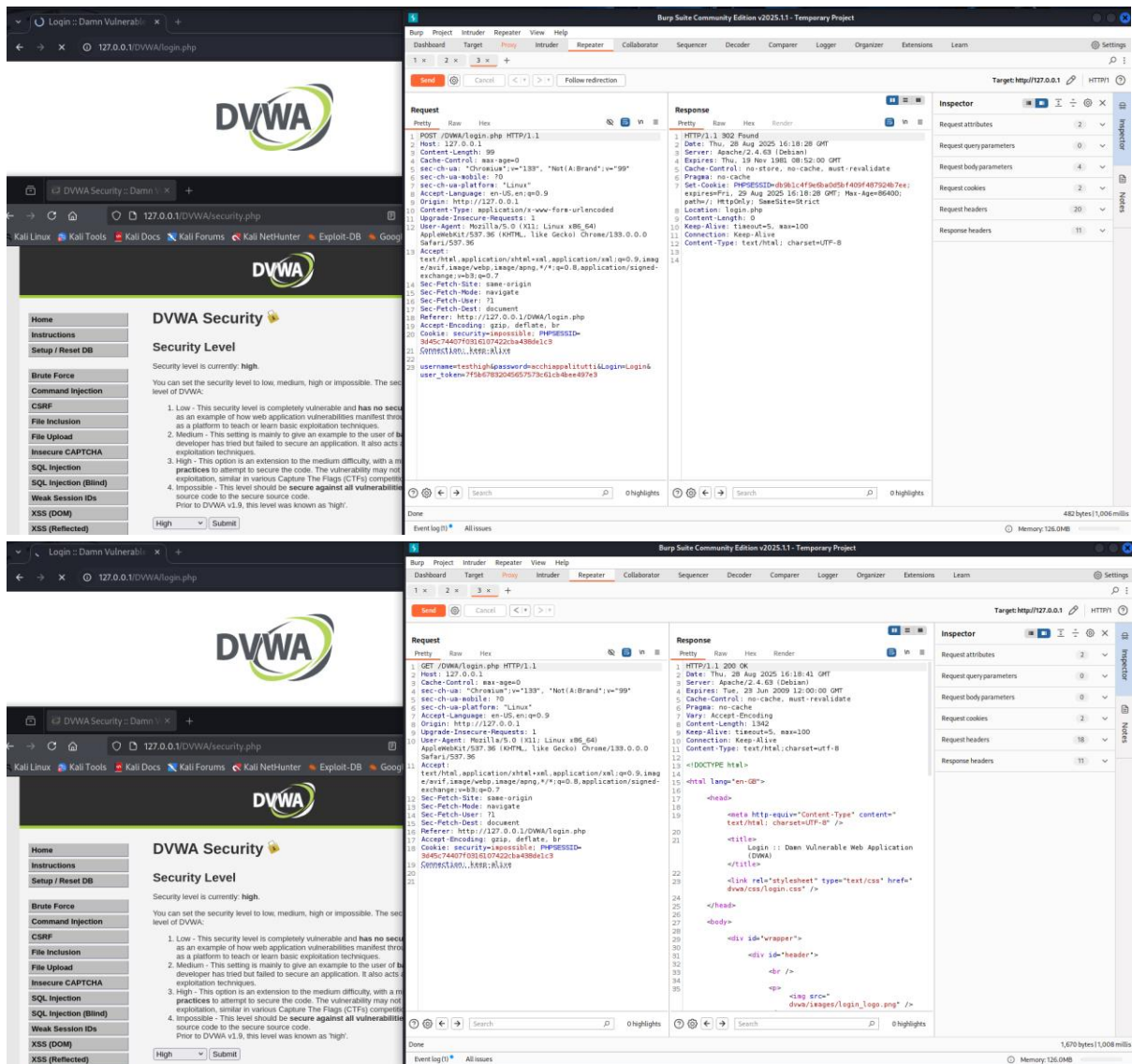
Abbiamo ripetuto il login e la navigazione in DVWA impostando il livello di sicurezza prima su **medium**, poi su **high**. In ciascuna prova abbiamo intercettato le richieste HTTP con Burp Suite per osservare come cambi il comportamento dell'applicazione.

Medium

High

The image displays two screenshots from a Kali Linux environment. The left screenshot shows the DVWA (Damn Vulnerable Web Application) Security Level page. The 'Security Level' is set to 'Medium'. The page lists four levels of security: Low (completely vulnerable), Medium (mainly to give an example), High (extension to medium difficulty), and Impossible (secure against all vulnerabilities). The 'Submit' button is visible at the bottom.

The right screenshot shows the Burp Suite Community Edition v2023.11 interface. The 'Request' tab is selected, showing the HTTP request details for the target URL `http://127.0.0.1/DVWA/login.php`. The request is a POST method with a content length of 101. The response tab shows the HTTP response details, including the status code 200 OK and the content type `text/html; charset=utf-8`. The 'Inspector' tab is also visible, showing the request and response headers and cookies.



Se la risposta fosse stata index.php, che significa login riuscito, DVWA ci reindirizzerebbe alla home dell'applicazione. In Burp Suite, vedremo un HTTP 302 Found. Questo redirect è il segnale che l'autenticazione è andata a buon fine.

8. Conclusioni

Il percorso seguito dimostra l'importanza di:

- Configurare correttamente tutti i componenti (network, database, web server, PHP) prima di testare.
- Usare strumenti come Burp Suite per avere controllo delle richieste HTTP.

Questa metodologia riproduce in piccolo il flusso di lavoro di un penetration tester professionista, enfatizzando il ciclo “configura – attacca – analizza”.